

PARCIAL GLOBAL

ETHICAL HACKING Y PENETRATION TESTING

Evaluación integral basada en PTES // Edición CTF Azul Neón

MODALIDAD	Trabajo práctico grupal
TIPO	Parcial global integrador
VALOR	100 puntos // Nota máxima 5.0
ENTREGABLE	Un único informe profesional en PDF con todas las evidencias integradas

PRINCIPIO RECTOR

El objetivo no es solamente obtener **root**. Se evaluará la capacidad de descubrir, analizar, validar, explotar de forma controlada, documentar el impacto y comunicar profesionalmente los hallazgos.

LAB STATUS: AUTHORIZED // ISOLATED // CONTROLLED

1. OBJETIVO GENERAL

Cada grupo asumirá el rol de un **equipo profesional de Penetration Testing** contratado para evaluar la seguridad de una máquina virtual deliberadamente vulnerable asignada por el docente. El proceso deberá ejecutarse siguiendo la metodología PTES y quedar documentado de forma verificable y profesional.

- Definir alcance, límites y reglas de compromiso.
- Descubrir y enumerar la superficie de ataque.
- Identificar, investigar y validar vulnerabilidades.
- Realizar explotación controlada y obtener acceso inicial cuando sea posible.
- Analizar post-explotación y escalamiento de privilegios.
- Construir una cadena de ataque basada en evidencia.
- Evaluar impacto y formular remediaciones técnicamente justificadas.
- **Integrar todas las evidencias dentro del informe PDF final.**

2. ESCENARIO

Una organización solicita una evaluación autorizada sobre uno de sus servidores. La pregunta central del ejercicio es:

PREGUNTA DE EVALUACIÓN

¿Puede un atacante con acceso a la misma red comprometer el servidor, acceder a servicios o información relevante y alcanzar privilegios administrativos?

Cada grupo trabajará exclusivamente sobre su máquina asignada y deberá descubrir progresivamente la superficie de ataque dentro de un entorno controlado.

3. GRUPOS Y MÁQUINAS ASIGNADAS

Grupo	Máquina asignada
Reyes del Phishing	Kioptrix Level 1 (#1)
CJJJ Corporation	FristiLeaks 1.3
Mzlhack	DC-1
404 Security Not Found	Stapler: 1
Cookies con Leche	BSides Vancouver 2018 Workshop
Grupo 6	SickOs: 1.2
Equipo 7	pWnOS 2.0

ASIGNACIÓN OFICIAL

Los siete grupos corresponden a la asignación oficial del parcial, incluyendo Grupo 6. Cada equipo debe trabajar únicamente sobre la VM indicada en esta tabla.

4. ARQUITECTURA DEL LABORATORIO

- **Máquina atacante:** Kali Linux, Parrot Security OS u otra distribución autorizada.
- **Red:** Host-Only o Internal Network.
- **Objetivo:** VM vulnerable asignada al grupo.
- **Descubrimiento:** la identificación de la IP del objetivo hace parte del ejercicio.

AISLAMIENTO OBLIGATORIO

Las máquinas vulnerables no deben exponerse directamente a Internet ni utilizarse en modo Bridge sobre redes institucionales.

5. REGLAS DE COMPROMISO

Actividades permitidas

- Descubrimiento de hosts y escaneo TCP/UDP cuando resulte pertinente.
- Fingerprinting y enumeración de servicios, usuarios, recursos y tecnologías.
- Análisis web, enumeración de directorios y revisión de configuraciones expuestas.
- Investigación, validación y explotación controlada de vulnerabilidades.
- Obtención de shell, cracking de hashes dentro del alcance y escalamiento de privilegios.
- Uso o adaptación de exploits públicos, scripts propios y herramientas especializadas.

Actividades prohibidas

- Atacar infraestructura institucional, servicios públicos en Internet o equipos de otros grupos.
- Atacar computadores personales o cualquier activo fuera del alcance.
- Realizar denegación de servicio, borrado deliberado, ransomware, wipers o persistencia permanente.
- Usar la máquina comprometida como plataforma para atacar otros sistemas.

6. METODOLOGÍA PTES

Fase	Objetivo	Evidencia esperada
1. Pre-Engagement	Definir condiciones y límites	Alcance, tipo de prueba y Rules of Engagement
2. Intelligence Gathering	Descubrir superficie de ataque	IP, puertos, servicios, versiones y tecnologías
3. Threat Modeling	Priorizar vectores	Activos, superficie e hipótesis de ataque
4. Vulnerability Analysis	Identificar y validar fallas	CVE/CWE/CVSS, pruebas y falsos positivos
5. Exploitation	Demostrar impacto	PoC, acceso inicial y nivel de privilegio
6. Post-Exploitation	Medir profundidad del compromiso	Enumeración local y escalamiento
7. Reporting	Comunicar resultados	Informe ejecutivo + técnico con evidencias integradas

7. PRE-ENGAGEMENT INTERACTIONS

- Definir el objetivo del pentest y la pregunta de seguridad que se pretende resolver.
- Documentar alcance: máquina, IP, hostname, red, servicios y tecnologías.
- Definir exclusiones y límites.
- Clasificar el ejercicio como Black Box, Gray Box o White Box, justificando la elección.
- Establecer Rules of Engagement, condiciones de parada y tratamiento de evidencias.

8. INTELLIGENCE GATHERING

El grupo deberá documentar el descubrimiento del objetivo y su enumeración. Una captura aislada no constituye análisis; cada evidencia debe ser interpretada técnicamente.

- Dirección IP, conectividad y hostname cuando sea posible.
- Puertos TCP y, cuando aporte valor, UDP.
- Protocolos, servicios, versiones y sistema operativo probable.
- Servidor web, CMS, frameworks y tecnologías.
- Directorios, archivos, usuarios y recursos compartidos.
- Servicios de autenticación, bases de datos, DNS y Virtual Hosts cuando existan.

CRITERIO DE CALIDAD

Una captura de Nmap sin interpretación tendrá valor limitado. Se debe explicar qué significa el resultado, cuál es su relevancia y cómo modifica la estrategia de evaluación.

9. THREAT MODELING

El grupo deberá construir un modelo básico de amenazas conectando activos, superficie de ataque y posibles caminos de compromiso.

Puerto	Servicio	Exposición / riesgo potencial	Prioridad
22	SSH	Acceso remoto y autenticación	Media
80	HTTP	Aplicación y contenido expuesto	Alta
445	SMB	Recursos, usuarios y permisos	Alta

Hipótesis de ataque: Servicio → vulnerabilidad → acceso inicial → enumeración local → escalamiento → compromiso.

10. VULNERABILITY ANALYSIS

La investigación deberá apoyarse en fuentes técnicas confiables como NVD, CVE, CWE, CISA, OWASP, Exploit Database, Searchsploit, advisories de fabricantes y documentación especializada.

DIFERENCIACIÓN OBLIGATORIA

Posible vulnerabilidad: existe evidencia que sugiere exposición. **Vulnerabilidad confirmada:** el equipo ha realizado validación técnica suficiente. Un resultado automático de un scanner no confirma por sí solo un hallazgo.

Contenido mínimo por hallazgo

- ID del hallazgo (PT-001, PT-002, etc.).
- Nombre, activo afectado, IP, puerto y servicio.
- Descripción técnica y evidencia.
- Severidad, CVSS y vector CVSS cuando corresponda.
- CVE y CWE cuando apliquen.
- Procedimiento de reproducción.
- Impacto técnico e impacto para la organización.
- Recomendación concreta y referencias técnicas.

11. EXPLOITATION

Las vulnerabilidades confirmadas podrán ser explotadas de manera controlada. El grupo deberá explicar por qué el objetivo era vulnerable, qué técnica fue utilizada, qué configuración fue necesaria y cuál fue el resultado.

- 1 Identificar la vulnerabilidad seleccionada.
- 2 Explicar la evidencia utilizada para confirmarla.
- 3 Describir exploit, técnica, payload o procedimiento empleado.
- 4 Registrar parámetros relevantes.
- 5 Mostrar el resultado y el nivel de acceso obtenido.
- 6 Relacionar la explotación con el hallazgo previamente documentado.

Demostración del acceso

Cuando se obtenga una shell, la evidencia deberá demostrar que corresponde a la máquina objetivo. Cuando el sistema lo permita:

```
whoami id hostname ip addr pwd uname -a
```

12. POST-EXPLOITATION

Una shell inicial no representa la finalización del ejercicio. El equipo deberá determinar hasta dónde puede avanzar un atacante una vez comprometido el sistema.

- Usuarios y grupos.
- sudo, SUID, SGID y capabilities.
- Cron jobs, servicios y procesos.
- Permisos de archivos y directorios.
- Archivos de configuración y credenciales almacenadas.
- Hashes, claves SSH e historial de comandos cuando resulte relevante.
- Versión de kernel, software vulnerable y configuraciones inseguras.
- Reutilización de contraseñas.

PROOF OF COMPROMISE

Si se alcanza el máximo nivel de privilegios, se deberá incluir una evidencia final que muestre como mínimo usuario, privilegios y hostname. El objetivo es demostrar el compromiso de forma verificable.

Cadena de ataque

El informe debe incluir un diagrama propio que conecte los pasos reales del grupo: **Reconocimiento** → **Enumeración** → **Vulnerabilidad** → **Explotación** → **Acceso inicial** → **Enumeración local** → **Escalamiento** → **Root o máximo privilegio alcanzado**.

13. REPORTING Y EVIDENCIAS

REGLA PRINCIPAL DE ENTREGA

TODAS las evidencias deben quedar dentro del informe PDF. No se entregará una carpeta externa de evidencias y no se considerará información que no esté integrada en el documento final.

Esto incluye, según corresponda: descubrimiento, escaneos, enumeración, tecnologías, directorios, hallazgos, validaciones, PoC, explotación, shells, post-explotación, escalamiento, flags relevantes y proof of compromise.

Tratamiento de cada evidencia

- 1 Asignar número y título a la figura.
- 2 Insertar la captura legible dentro del informe.
- 3 Explicar qué se ejecutó.
- 4 Explicar qué demuestra la evidencia.
- 5 Explicar por qué es relevante y qué conclusión se obtuvo.

TRAZABILIDAD

Debe ser posible reconstruir el ataque leyendo solamente el PDF: servicio identificado → enumeración → validación → explotación → acceso → post-explotación → escalamiento.

14. ESTRUCTURA OBLIGATORIA DEL INFORME

- 1 Portada
- 2 Control documental
- 3 Tabla de contenido
- 4 Resumen ejecutivo
- 5 Objetivos
- 6 Alcance
- 7 Exclusiones
- 8 Rules of Engagement
- 9 Metodología PTES
- 10 Arquitectura del laboratorio
- 11 Reconocimiento e Intelligence Gathering
- 12 Enumeración
- 13 Threat Modeling
- 14 Análisis de vulnerabilidades
- 15 Resumen de hallazgos
- 16 Explotación
- 17 Post-Exploitation
- 18 Escalamiento de privilegios
- 19 Cadena de ataque
- 20 Hallazgos técnicos detallados
- 21 Proof of Compromise
- 22 Recomendaciones
- 23 Conclusiones
- 24 Referencias
- 25 Anexos técnicos cuando sean necesarios, siempre dentro del mismo PDF

Resumen de hallazgos — formato sugerido

ID	Hallazgo	Severidad	CVSS	Estado
PT-001	Ejemplo de vulnerabilidad	Critical	9.8	Confirmado
PT-002	Configuración insegura	High	8.1	Confirmado
PT-003	Divulgación de información	Low	3.7	Confirmado

15. HERRAMIENTAS PERMITIDAS

Podrán utilizarse herramientas como Nmap, Burp Suite, Gobuster, Feroxbuster, Dirsearch, Nikto, WhatWeb, Searchsploit, Exploit Database, Metasploit, Netcat, Hydra, John the Ripper, Hashcat, LinPEAS, Linux Smart Enumeration, Python, Bash y herramientas desarrolladas por los estudiantes.

LA HERRAMIENTA NO ES LA RESPUESTA

La calificación no dependerá de cuántas herramientas se ejecuten, sino de la capacidad para seleccionar técnicas adecuadas, interpretar resultados, validar hallazgos y explicar el proceso.

16. WALKTHROUGHS Y DEFENSA TÉCNICA

Queda prohibido consultar walkthroughs, writeups, videos o tutoriales que resuelvan específicamente la VM asignada. Sí se permite consultar documentación general de herramientas, protocolos, sistemas operativos, CVE/CWE, técnicas y documentación oficial.

Defensa técnica

Cualquier integrante podrá ser seleccionado para explicar una captura, un comando, una vulnerabilidad, un CVSS, un CVE/CWE, la explotación, el escalamiento, el impacto o una recomendación. Todos los integrantes deben comprender el ataque completo.

17. ENTREGABLE

ÚNICO ARCHIVO

Cada grupo entregará **un único archivo PDF**. No se requiere carpeta adicional de capturas ni carpeta externa de evidencias.

Formato recomendado:

PARCIAL_PENTEST_NOMBREDELGRUPO_MQUINA.pdf

Ejemplo:

PARCIAL_PENTEST_REYES_DEL_PHISHING_KIOPTRIX_1.pdf

18. RÚBRICA DE EVALUACIÓN

Componente	Puntaje
Pre-Engagement, alcance y Rules of Engagement	5
Intelligence Gathering y enumeración	10
Threat Modeling	5
Vulnerability Analysis	15
Explotación y demostración técnica	20
Post-Exploitation y escalamiento	10
Calidad profesional del informe	25
Defensa técnica	10
TOTAL	100

Desglose de los 25 puntos del informe

Criterio	Puntos
Resumen ejecutivo	3
Alcance y metodología	2
Organización y presentación profesional	3
Documentación de vulnerabilidades	5
Calidad y trazabilidad de evidencias	5
Evaluación del impacto	2
Recomendaciones técnicas	3
Cadena de ataque y conclusiones	1
Referencias técnicas	1
TOTAL	25

19. INFORMES PROFESIONALES DE REFERENCIA

Estos documentos pueden utilizarse como referencia de estructura, jerarquía de información, presentación de hallazgos, evidencias y recomendaciones. No deben copiarse textos ni soluciones; el objetivo es observar el nivel esperado de un reporte profesional.

Cure53 — Pentest Report Project 11 Web App UI, API & Infrastructure

Ejemplo de reporte técnico conciso con alcance, hallazgos individualizados, severidad, detalle técnico, pruebas y conclusiones.

[Descargar informe oficial de Cure53](#)

Bishop Fox — Winston Privacy Assessment Report

Ejemplo de separación entre reporte ejecutivo y vulnerabilidades técnicas, con alcance, conteo por severidad, impacto y recomendaciones.

[Descargar informe de Bishop Fox](#)

CRITERIO FINAL

Un grupo puede alcanzar **root** y obtener una calificación baja si no demuestra cómo descubrió el vector, por qué funcionó, qué impacto tiene, cómo escaló privilegios, qué evidencias lo sustentan y cómo se remedia. Se evalúa el proceso completo de pentesting.

END OF BRIEF // GOOD LUCK, OPERATORS